CS 03351: Student Assignment – Developing a Cybersecurity Program
Braden Elsworth, Blake Richardson, Jason Ong
Cybersecurity Program

Objective: Design a comprehensive cybersecurity program for a fictional mid-sized organization using Security+ principles. Apply concepts across all Security+ domains, including threats, risk management, identity and access management, cryptography, and incident response.

Directions:

Step 1: Define the Organization - Choose or be assigned an industry (e.g., healthcare, finance, retail, education, government). - Describe the organization's size, IT infrastructure, and regulatory requirements. - Identify its critical assets (e.g., customer data, financial records, intellectual property).

Secure Bank

Our organization is a regional bank, it's in the finance sector and must handle customer financial records securely. Has to abide by legislation such as the GLBA, industry standards such as PCI-DSS,

Step 2: Conduct a Risk Assessment - Identify potential threats and vulnerabilities. - Rate risks by likelihood and impact using a risk matrix. - Select the top 3–5 high-priority risks for mitigation.

	Minor	Moderate	Severe
Likely	Check fraud	Phishing	Data Breaches
Possible	Human error	ATM Tampering	Ransomware
Unlikely	Theft	Robbery	Data Loss

Step 3: Security Policies and Governance - Draft at least three security policies (e.g., password policy, acceptable use policy, incident response policy). - Ensure policies align with compliance requirements (HIPAA, PCI-DSS, GDPR, etc.).

- Incident response policy
    - Ensure regular review and revision of this policy over time
    - Designates an incident manager that assumes the role of a supervisor
        - Considers the wider/big-picture situation
            - Is not involved with technical tasks, only works to manage
    - Designates a technical manager
        - Has the relevant knowledge to handle technical tasks
        - Additional technical staff can be brought in by the technical manager as a situation demands with the permission of the incident manager
    - Designates a communications manager
        - Functions as a liaison between Secure Bank and the public
        - Provides live updates to external parties as needed
    - Defines and designates roles for other staff during an incident
    - *Specifics of Incident Response to be documented in Step 7 § Incident Response*
    - Post-mortem

        - Comprehensive study of the timeline of the incident
            - What happened
                - Why did it happen?
                - How did it happen?
            - What worked well
            - What didn't work well
        - Lessons learned used to inform future policy

- Password policy
    - Password uniqueness
        - Password cannot be the same as any previously-used password
    - Password complexity
        - Password must be between 12 and 24 characters (inclusive)
        - Password must contain at least two numbers and two special characters ([/*-+_!@#$%^&\|])
        - Password may not contain three or more of the same character consecutively
    - Password expiry
        - Enforces mandatory password changes at regular intervals
            - Enforced account lock upon failure to change password by deadline

- Acceptable Use policy
        - This is imagined to be a much more general and comprehensive policy, but only the security-related elements are documented in this project
    - Users of Secure Bank's software are forbidden from using the software to facilitate criminal activity or acts of terrorism
    - Users are forbidden from using Secure Bank's services in ways that compromise the function and/or integrity of Secure Bank

- Employee Hardware/Software policy
    - Under no circumstances may an employee provide access to company hardware or software to any person other than direct superiors
    - Employees are not allowed to connect external devices to company equipment
        - External devices are defined as any device that is not provided and expressly approved by Secure Bank
    - Employees are to use Secure Bank's hardware and software only for the task they are assigned
    - Employees who work remotely are not allowed to move equipment out of the United States and/or work from locations outside of the United States without express permission
        - Enforced to ensure compliance with regulations
    - Employees must remain within the same room as equipment that is logged in to or being operated
        - Intended to minimize the potential vulnerability of unattended hardware

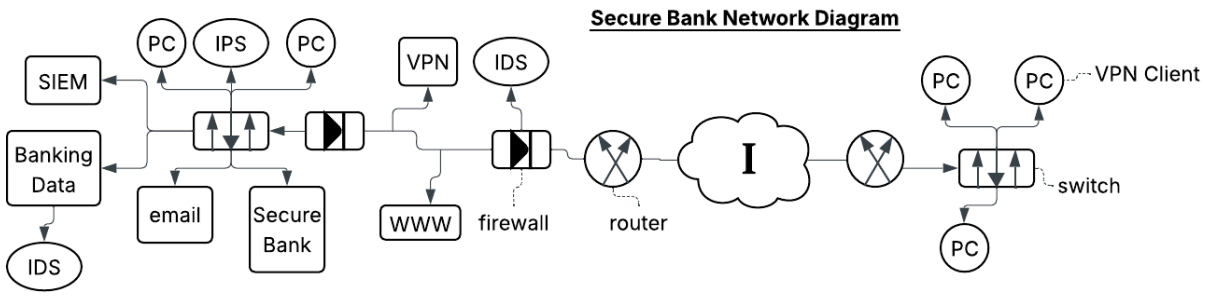
Step 4: Access Control and Authentication - Choose an access control model (RBAC, DAC, MAC). - Describe authentication and authorization strategies, including MFA. - Address privileged account management.

RBAC, where we will divide permissions based on roles in the company.

Anyone accessing network will go under MFA, multi-factor authentication

Step 5: Network and Infrastructure Security - Design a basic secure network architecture, including

segmentation, firewalls, IDS/IPS, and VPN access. - Identify how wireless and remote access will be secured.



Step 6: Data Protection and Cryptography - Select methods for protecting data at rest (disk/database encryption), in transit (TLS, VPN), and in use (application/memory protections). - Justify choices of cryptographic algorithms.

Devices and data should be encrypted, transmitted data should be end-to-end encrypted. Employees must use a company VPN if they're working remotely.

At no point should external devices be used by employees for work purposes

Step 7: Monitoring and Incident Response - Develop a monitoring strategy (SIEM logs, intrusion detection, endpoint monitoring). - Create an incident response playbook covering detection, containment, eradication, recovery, and lessons learned.

- Monitoring
- Incident Response
    - Detection
    - Containment
    - Eradication
    - Recovery
    - Lessons learned
        - ➢ *Incident Response Policy in Step 3 § Post-mortem*

Step 8: Training and Awareness - Outline a user security awareness program including phishing simulations, regular training, and reporting procedures.

- Awareness: Social engineering attacks
    - Regular and mandatory training covering theoretical and real implementations of social engineering attacks
- Random and unannounced phishing simulations to reinforce training
-

Step 9: Evaluation and Continuous Improvement - Propose metrics to measure program effectiveness (number of incidents, patch compliance, phishing test results). - Describe how the program will be updated annually to address emerging threats.

- Number of incidents
- Patch compliance
- Phishing test results
    - <5% failure rate considered a success

Deliverables: 1. Written Report (5–8 pages) describing the cybersecurity program. 2. Risk Assessment Table (completed risk matrix). 3. Security Policies (at least three drafted policies). 4. Network Diagram (visual representation of secure architecture). 5. Presentation (10 minutes) summarizing the cybersecurity program to executive leadership.

1

Grading Rubric (suggested): - Risk Assessment and Mitigation Planning – 25 pts - Security Policies – 15 pts - Network Architecture & Diagrams – 15 pts - Data Protection & Cryptography – 15 pts - Monitoring, Incident Response & Awareness Program – 20 pts - Presentation Quality – 10 pts

The organization that we are building our cybersecurity program around is a fictional mid-sized organization called Secure Bank. Our organization is a regional bank in the finance sector that must keep important data secure. That data includes our critical assets which are customer data, financial records, transactions, loans and investments, physical assets, and our employees.

Since Secure Bank is based out of the United States, there are many regulatory requirements that must be met. Primary regulatory requirements we must follow include:

1. GLBA (Gramm-Leach-Billey Act): The GLBA is a federal law that requires Secure Bank to explain our information-sharing practices to our customers and to safeguard sensitive data.
2. PCI DSS: This global security standard requires Secure Bank to have a maintained secure network and to protect cardholder data.
3. FDIC (Federal Deposit Insurance Corporation): Secure Bank will need to pay regular insurance premiums to the FDIC, a U.S. government agency, in order to be provided deposit insurance, supervision, and bank resolution.
4. AML (Anti-Money Laundering): This comprehensive system of laws and

regulations allows Secure Bank to prevent criminals from illegally obtaining money through our bank.

5. ECOA (Equal Credit Opportunity Act): This federal law prohibits Secure Bank from discriminating against credit applicants. This law also states that we must provide applicants with reasoning as to why we have denied credit, if requested.

Next, we have conducted a risk assessment by developing a risk matrix for our cybersecurity program.

	Minor	**Moderate**	**Severe**
Likely	Check fraud	Phishing	Data Breaches
Possible	Human error	ATM Tampering	Ransomware
Unlikely	Theft	Robbery	Data Loss

In this risk matrix above, we have identified nine potential risks that our organization may face. We have then labeled each risk into a color corresponding to the level of importance our organization needs to worry about these risks. In green, we have the risks that are less likely to occur and overall won't negatively impact the entire organization that severely. In yellow, we have moderate risks with a higher potential to occur. These risks should have solutions in place in case any of these risks were to occur, however large amounts of resources should not be spent on prevention of such risks. In red, we have the most severe risks with a fair probability of occurring. The risks should have clear preventive measures to avoid them and strong solutions in case one does occur.

The most notable risk that we have identified is data breaches. Since Secure Bank regularly takes in important data like financial information, customer data, and account data, we must prioritize preventing data breaches with the utmost care. Other important risks we have identified are phishing attempts and ransomware. We must make sure that our employees do not fall for phishing schemes, however we must prevent the more likely outcome that our customers can't differentiate our emails from online impersonators. For ransomware attacks, if one were to happen to Secure Bank then

without any backups in place, we can experience major financial and data loss.

To prevent these high level risks and any other sort of negative potential outcomes, we have developed several security policies that our organization will adopt.

First, we must have an extensive incident response policy that aims to have strategies and procedures for handling any incidents regarding cybersecurity. Parts of this incident response policy include having an incident manager, technical manager, and a communications manager. The incident manager will assume the role of a supervisor and will consider the wider/big-picture of situations. Will not be involved in technical tasks, only works to manage. The technical manager will have the knowledge required to handle technical tasks. Additional technical staff can be brought in by the technical manager as a situation demands with the permission of the incident manager. The communication manager will act as a liaison between Secure bank and the public. Will provide live updates to external parties as needed.

Other important sections of our incident response policy include defining and designating roles for other staff during an incident. Another is the creation of a post-mortem system that utilizes a comprehensive study of the timeline of an incident. We will look at what happened in the incident and ask important questions such as why did it happen, how did it happen, what worked well, and what didn't work well? Lastly, we will include specifics of incident response, which we will discuss later in our general incident response section of the cybersecurity program.

For our other security policy, we have developed a strict password policy that all employees must follow. This policy includes a password expiry system that requires employees to routinely change their passwords after a set duration of time. Failure to change passwords in time will result in account lock up that will need to be unlocked through IT. These renewed passwords must all be unique, meaning that an employee cannot reuse the same password as they have previously. Finally, we have created a strict password complexity model. Passwords must be between 12 and 24 characters (inclusive). Passwords must contain at least two numbers and two special characters, such as ([/*-+_!@#$%^&\|]). Lastly, passwords may not contain three or more of the same character consecutively.

The third policy is a group of two separate policies, one intended for the

customers of Secure Bank, and the other for employees. As the customer-facing policy is the Acceptable Use policy that is intended to be a general policy governing allowable use of Secure Bank's products and services, much of its contents are not security-related and are omitted for the purposes of the report.

The Acceptable Use policy binds customers to an agreement not to use Secure Bank's services to perpetrate, facilitate, or be an accessory to criminal or terroristic activities, as well as an agreement not to use Secure Bank's products and services in ways that compromise the functions and/or integrity of Secure Bank.

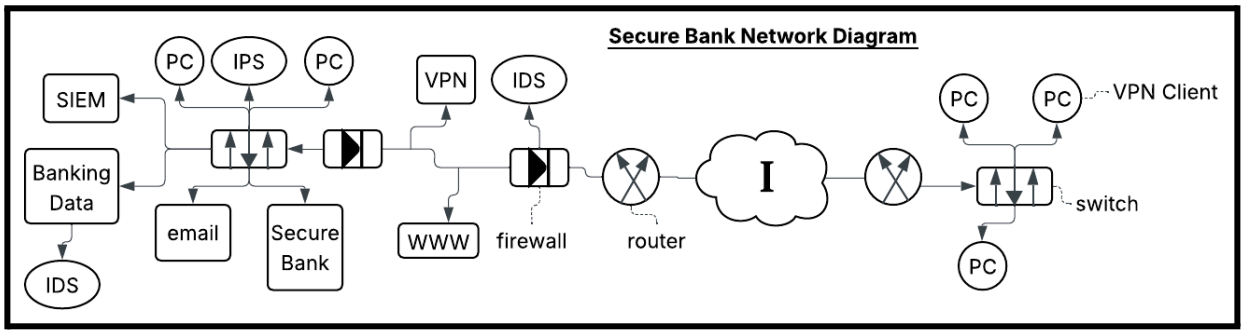
The internal Employee Hardware/Software policy is intended to define allowed use of Secure Bank's infrastructure by employees. The policy seeks to ensure that access to Secure Bank's internal systems and data is exclusive to employees by guiding behavior such that the potential for access by external parties by way of Secure Bank's equipment is minimized. This is accomplished by forbidding employees from providing use of equipment to unauthorized individuals, forbidding the use and/or interfacing of external equipment to Secure Bank's infrastructure, forbidding the use of Secure Bank's equipment for any purpose not pertinent to the task an employee is assigned, and requiring that employees remain in the same location as equipment that they are actively logged in to and/or operating. In addition, the policy requires all equipment and access to said equipment to be within the bounds of the United States, so as to maintain security and compliance with regulations.

The next important aspect of our cybersecurity program is our access control model. We have decided that the best model suited for Secure Bank is an RBAC, also known as Role-Based Access Control. Through this control model, we will divide permissions through our company based on each employee's role.

We have also decided that MFA, or multi-factor authentication, will be required by anyone accessing our network. That means that when employees are logging on to our network, they will have to use a secondary application such as their email or messages to authenticate themselves as actual Secure Bank employees. Utilizing MFA will allow our bank to be more secure and will prevent potential criminals from secretly logging into our employee's accounts.

In the next section of our cybersecurity program, we have created a network

diagram for Secure Bank to follow.



In this network diagram above, we have marked important network architecture such as firewalls, routers, switches, VPNs, IDS, and IPS. In this basic network diagram, we highlight the layout of one potential building's network and a potential client. Also shown in the diagram is a SIEM. With this SIEM, we will analyze logs from the workday to make sure that there are no unauthorized actions or logins. Since our bank may be taking in a lot of data and devices on our network, we will have an intrusion prevention system behind all of our firewalls in order to prevent possible intrusions. The final, most noteworthy integration in our network diagram is an intrusion detection system within our banking data that will monitor all data and transactions that pass into or out of our banking data.

For data protection and cryptography, we have determined that all devices and data within our network should be encrypted. Any devices, such as personal devices, that haven't undergone this encryption protocol will not be allowed on the network. Transmitted data should utilize end-to-end encryption. This form of encryption entails any data from a sender being encrypted and scrambled while being transmitted. Once the data is sent to a receiver, the data will then become decrypted and unscrambled. Another form of data protection and cryptography that we are utilizing is the requirement of employees being on a company VPN if they're working remotely. We also will enforce that at no point should external devices be used by employees for work purposes.

Our monitoring and Incident Response strategy comprises several parts, detection, containment, eradication, recovery, and a post-mortem. For detection, we will have comprehensive logging of all user activities and changes in the system to ensure integrity and auditability. This means we can keep track of what changes are made and

by which users, thus allowing us to identify what has been tampered with in the event of a security breach. Additionally, we will require that any off-premises traffic from our employees be routed via the company VPN, and block anything else to ensure no unauthorized access to internal systems. Data on usual traffic patterns can be collected to know what normal system traffic looks like, which can then be used to identify anomalies that could indicate suspicious activity on the network and warn the incident response team. Once a security incident is detected, it must be contained. Containment can be accomplished using the previous detection systems, quarantining affected files and systems that were edited by the breached account, proactively blocking IPs with suspicious traffic, and shutting down affected systems while contacting the incident response team. In addition to identifying affected systems, the auditability can help with eradication and rollbacks, by finding and eliminating tampered with files. In the event proper rollbacks are not possible due to persistent threats, systems may have to be completely reset to the recovery backup systems. The recovery system includes offsite backups, and air gapped recovery systems. These will be guaranteed to be secure in the event of a catastrophic ransomware incident, allowing the incident response team to get critical systems back online to minimize losses and client inconvenience. Finally, as part of the post-mortem, clients will be promptly warned of data breaches if their data was subject to a breach, and the incident response team will go over what happened. How the incident was allowed to happen, what could have prevented it, what could have been done better, what was done well, and finally a conclusion to carry into future security policy to avoid similar situations in the future. With these steps, our Incident Response Strategy allows our system to detect, contain, & eradicate threats, recover critical systems, and draw conclusions to inform future security policy.

New employees will undertake security training as part of their onboarding, this includes making employees aware of common threats, how to avoid them, as well as how to properly report a security threat should they encounter one. Along with onboarding security training, all existing employees should undergo annual security training with the most up-to-date security information. External communications or emails should be marked distinctly and clearly from internal Company communications or emails to minimize employee confusion and social engineering attacks. Finally, to test the employees' readiness in encountering these threats, simulated phishing attempts should be set up by the IT department on all employees, and those that fall for it undergo mandatory retraining.

To evaluate the effectiveness of our security program and identify potential improvements, several metrics will be used. Firstly, the number of security incidents that occur, obviously if this number is high the observations from the incidents' respective postmortems must be implemented to ensure issues of a similar nature don't reappear. Additionally, all systems should be getting patches and updates automatically and as soon as possible. If a fix already exists for a vulnerability, that vulnerability should never be the reason our systems have an incident. Additionally, we can collect statistics on the employee simulated phishing attempts to get a general idea of how prepared and informed our employees are at dealing with phishing and security threats. With all this data, we can identify the greatest threats and dynamically adapt our security measures to focus on existing threat vectors, outdated and vulnerable systems, or social engineering vulnerability in our employees, respectively.

Contributions:

Braden Elsworth: Helped create risk matrix, created network diagram, looked into and wrote regulatory requirements, adapted steps 1-6 into written report

Blake Richardson: Monitoring and Incident report, Training and awareness, Evaluation and continuous improvement (Steps 7-9 in written report).

Jason Ong: Drafted policies, adapted Acceptable Use policy/Employee Hardware/Software policy into written report